KiKi Pentester - Security Report

Executive Summary

Target URL: https://httpbin.org/html

Scan Date: 2026-02-05T20:05:01.148773+00:00

Status: completed

Pages Analyzed: 1

Vulnerabilities Found: 7

Vulnerability Summary by Severity

Severity	Count
Critical	0
High	1
Medium	2
Low	4
Info	0

OWASP Top 10 2025 Coverage

OWASP ID	Category	Findings
A01	Broken Access Control	0
A02	Security Misconfiguration	7
A03	Software Supply Chain Failures	0
A04	Cryptographic Failures	0
A05	Injection	0
A06	Insecure Design	0
A07	Authentication Failures	0
A08	Software or Data Integrity Failures	0
A09	Logging & Alerting Failures	0
A10	Mishandling of Exceptional Conditions	0

Detailed Vulnerability Findings

1. [High] CORS Origin Reflection with Credentials

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/html
Description: CORS reflects origin and allows credentials
Evidence: Origin reflected: https://evil.com, Credentials: true
Remediation: Do not reflect arbitrary origins with credentials enabled

2. [Medium] Missing Security Header: Strict-Transport-Security

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/html
Description: HSTS not configured - enables man-in-the-middle attacks
Evidence: Header 'Strict-Transport-Security' not found in response
Remediation: Add the Strict-Transport-Security header to your server configuration

3. [Medium] Missing Security Header: Content-Security-Policy

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/html
Description: Missing CSP - increases XSS attack risk
Evidence: Header 'Content-Security-Policy' not found in response
Remediation: Add the Content-Security-Policy header to your server configuration

4. [Low] Missing Security Header: X-Content-Type-Options

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/html
Description: Missing X-Content-Type-Options - enables MIME-type sniffing attacks
Evidence: Header 'X-Content-Type-Options' not found in response
Remediation: Add the X-Content-Type-Options header to your server configuration

5. [Low] Missing Security Header: X-Frame-Options

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/html
Description: Missing X-Frame-Options - enables clickjacking attacks
Evidence: Header 'X-Frame-Options' not found in response
Remediation: Add the X-Frame-Options header to your server configuration

6. [Low] Missing Security Header: X-XSS-Protection

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/html
Description: Missing X-XSS-Protection header
Evidence: Header 'X-XSS-Protection' not found in response
Remediation: Add the X-XSS-Protection header to your server configuration

7. [Low] Missing Security Header: Referrer-Policy

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/html
Description: Missing Referrer-Policy - may leak sensitive URL information
Evidence: Header 'Referrer-Policy' not found in response
Remediation: Add the Referrer-Policy header to your server configuration